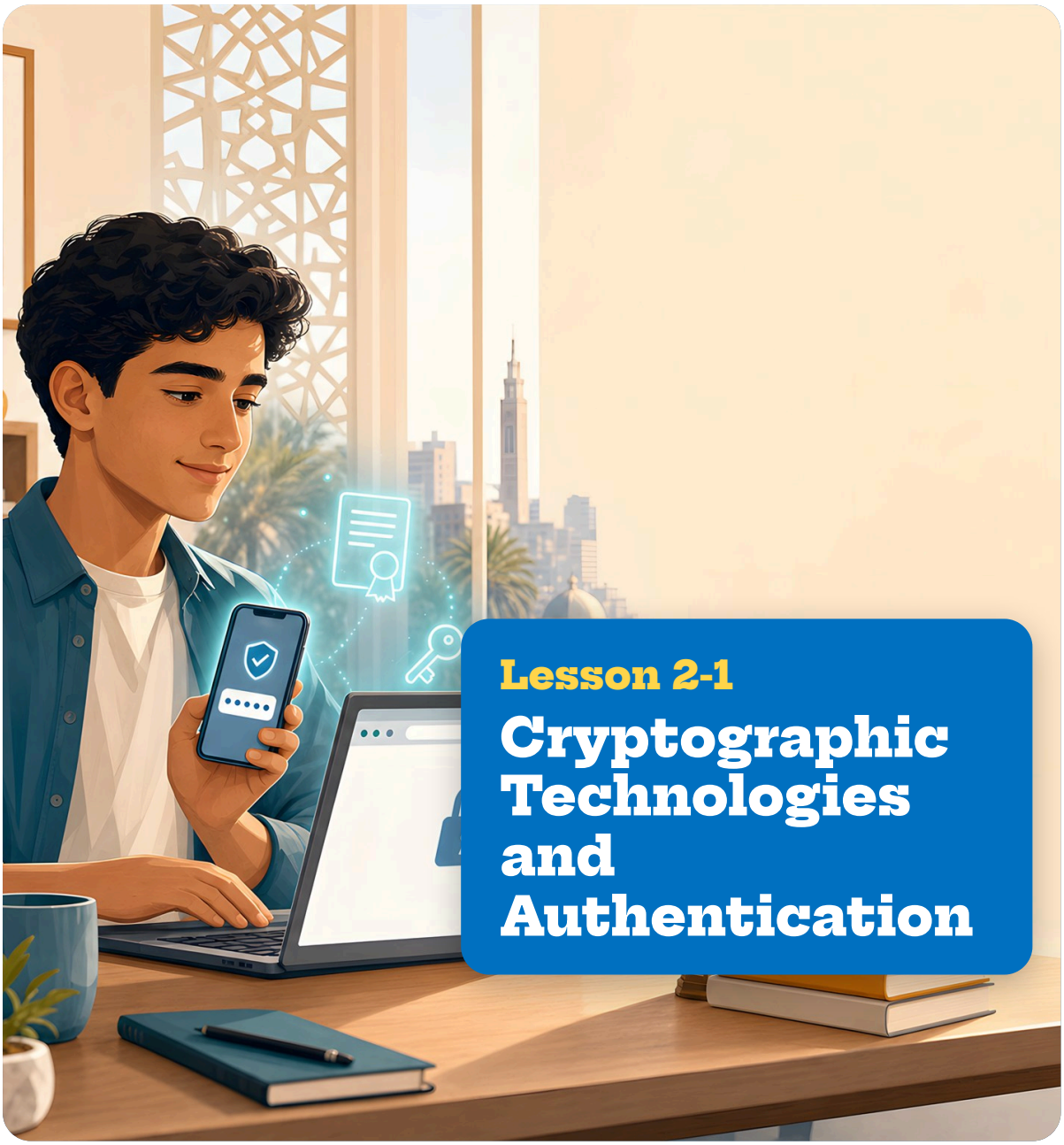


Lesson 2-1

Cryptographic Technologies and Authentication

Learning Objectives

- Explain how HTTPS secures communication: how the TLS handshake uses public-key cryptography to share a key safely, and how common-key cryptography then protects the data that follows.
- Describe how authentication, including multi-factor authentication, is used in real services, and explain why security technologies are combined.

Every time you log in to a bank app, buy something online, or open a website with a small padlock in the address bar, hidden technologies are working to keep your information safe. Messages are scrambled so no one else can read them, the website proves that it is genuine, and your identity is checked before you are granted access. Without these protections, passwords could be stolen and private data could be read by unauthorized people.

? Guiding question: How do cryptographic technologies and authentication work together to keep online communication and services secure?

Point!

1. How HTTPS Communication Works

(1) **(HTTPS (HTTP Secure))**…a communication protocol that adds TLS encryption to HTTP. By providing encryption, detection of tampering, and verification of the communication partner, it protects users from threats such as eavesdropping, tampering, and impersonation. The procedure for establishing a secure communication is called the TLS handshake.

(2) HTTPS combines common-key (symmetric-key) cryptography and public-key cryptography as follows, taking advantage of the strengths of both methods.

Stage	What happens	Cryptographic method used
① **Connection**	The web server sends a digital certificate and a public key to the browser. The browser verifies the server's authenticity through a certificate authority (CA).	Public-key cryptography
② **Key exchange**	The browser creates a common key for communication, encrypts it with the server's public key, and sends it. The server decrypts it with its private key to obtain the common key.	Public-key cryptography
③ **Data communication**	Data is encrypted and exchanged using the shared common key.	Common-key cryptography

Note: the exchange above shows one way a common key can be shared. Current versions of TLS use Diffie-Hellman key agreement instead.

Key Fact:
Secure online communication and services depend on combining cryptography and authentication — not on any single technology.

Key Concepts:

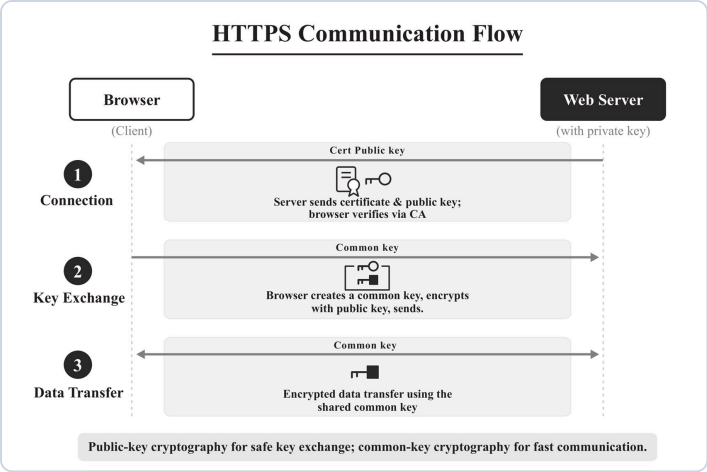
- HTTPS
- common-key cryptography
- public-key cryptography
- TLS handshake
- multi-factor authentication
- digital signature
- digital certificate
- non-repudiation

KEY TERMS

HTTPS — HTTP with TLS encryption added (encryption, tamper detection, and partner verification).



A public key locks; a different private key unlocks. In a digital signature the direction reverses: the private key signs and the public key verifies.



HTTPS Communication Flow

(3) Public-key cryptography is used to "share keys safely," and common-key cryptography is used to "exchange large amounts of data quickly." This division of roles makes it possible to achieve both security and communication speed.

2. Use of Authentication in Real Services

(1) Many services adopt **(multi-factor authentication)**, in which two or more of the three factors of authentication (knowledge, possession, biometric) are combined.

(2) When only one factor is used, an unauthorized party can gain access if that factor is broken. By combining multiple factors, even if one is broken, another can still prevent access.
e.g., If only a password (knowledge) is used, an unauthorized login is possible once the password is leaked. However, if a notification to a smartphone (possession) is also required, an attacker cannot log in without the device, even if the password is leaked.

(3) The following examples of multi-factor authentication are used in various services.

Service	Examples of authentication used
Online banking	Password (knowledge) + one-time password (possession)
SNS login	Password (knowledge) + SMS authentication (possession)
Company laptop login	Smart card (possession) + fingerprint authentication (biometric)
Online shopping	Password (knowledge) + one-time code from 3-D Secure (possession)

3. Combinations of Security Technologies

(1) Safe communication and services are achieved not by a single technology, but by combining multiple security technologies.



Strong login combines two or more different factors.

KEY TERMS
multi-factor authentication — combining two or more of the three factors: knowledge, possession, biometric.

Technology	Effect
Encryption (common-key, public-key)	Prevents communication content from being read by third parties
Digital signature	Detects data tampering or impersonation of the sender, and makes it impossible for the sender to deny having sent the data afterward (non-repudiation)
Digital certificate	Verifies that the communication partner is authentic
Multi-factor authentication	Prevents unauthorized logins

(2) For example, when purchasing a product through online shopping, these technologies are combined and used as follows.

① When you access the site, HTTPS communication begins, and **(encryption)** prevents communication content from being read by third parties.

② The browser checks the **(digital certificate)** to confirm that the destination is the genuine shopping site.

③ For account login, **(multi-factor authentication)** combining a password and SMS authentication, etc., prevents unauthorized logins.

④ When sending order details, a **(digital signature)** can also be used so that tampering during communication can be detected.

(3) By combining multiple technologies in this way, various threats such as "eavesdropping," "tampering," "impersonation," and "unauthorized login" can be addressed simultaneously.

✎ Worked Example

(1) Mark each statement (A–D) with ○ if true or × if false.

A HTTPS communication uses both public-key cryptography and common-key cryptography.

B HTTPS communication exchanges all data using public-key cryptography.

C Multi-factor authentication is a method that combines two or more of the three factors of authentication.

D An example of multi-factor authentication is setting two passwords.

(2) Match each threat (a–c) with the most appropriate security technology from the choices below (A–C).

a I want to prevent communication content from being read by third parties.

b I want to verify that data has not been altered during communication.

KEY TERMS
digital signature — detects tampering and impersonation, and provides non-repudiation.



A certificate authority vouches that a site is genuine.

💡 PAUSE & THINK

If a password is leaked, why can a second factor sent to a phone still keep the account safe?

KEY TERMS
public-key cryptography — shares a key safely.
common-key cryptography — exchanges data quickly.

c I want to verify that the communication partner is authentic.

[Choices] **A** Encryption **B** Digital signature **C** Digital certificate

✓ Solution

(1)

A HTTPS communication uses public-key cryptography for key exchange and common-key cryptography for data communication. Therefore, ○.

B Exchanging all data using public-key cryptography would be slow, so common-key cryptography is used for data communication. Therefore, ×.

C Correct definition of multi-factor authentication. Therefore, ○.

D Even if two passwords are set, both are "knowledge" factors, so this does not constitute multi-factor authentication (it is two-step authentication using the same factor). Therefore, ×.

(2)

a: Preventing reading of communication content is encryption. **A**

b: Detecting data tampering is a digital signature. **B**

c: Verifying the authenticity of the communication partner is a digital certificate. **C**

EXAM-STYLE QUESTION

Explain why HTTPS uses public-key cryptography to share the key but common-key cryptography to exchange the data. **[6] Refer to:** security and speed.

Try

1 Answer the following questions.

1. In HTTPS communication, what cryptographic method is used so that the browser and server can safely share a common key?
2. In HTTPS communication, what cryptographic method is used for data communication after the common key has been shared?
3. Briefly explain the reason for combining the cryptographic methods in (1) and (2), based on the characteristics of each method.

2 Answer the following questions.

(1) For each service (a–d), indicate which combination of authentication factors is used: **A** Knowledge + possession, **B** Knowledge + biometric, **C** Biometric + possession.

a Password + one-time password

b Password + fingerprint authentication

c Password + SMS authentication

d Face recognition + smart card

(2) From the following options (A–D), choose the one that is NOT an appropriate description of combinations of security technologies.

A Encryption is a technology that prevents communication content from being read by third parties.

B Digital signatures are a technology that improves communication speed.

C Digital certificates are a system for verifying that the communication partner is authentic.

D By combining multiple security technologies, various threats can be addressed.

Think as an Engineer — Investigate & Decide

A school in your city is building an online portal where students check their grades and pay fees. You must choose how students log in. Which is the better choice for this service?

☐ **A password only** ☐ **A password plus a one-time password sent to the phone**

1 · Collect data. Ask ten classmates which login methods they use and trust (password, one-time password, SMS, fingerprint or face). Record the results in a table and find the most common answer.

2 · Analyze the stakeholders. For each group — a student, the school, and a student with no smartphone — note one benefit and one drawback of requiring a second factor.

3 · Decide. Recommend one login method for the portal and give two reasons based on your survey and your table. **In pairs,** compare your recommendations and agree together on the single strongest reason before you write it down.

Give evidence for your answer.

Stuck? Start with the user: a password alone fails once it leaks; adding a possession factor (a one-time password) still blocks the login.

🌍 In a New Context

A small online shop wants to secure both customer login and payment. Using what you learned, name two security technologies it should use and say where each one helps, then identify one threat that could still remain.

❓ Lesson Question — Answered

The lesson asked how cryptographic technologies and authentication keep communication and services secure. HTTPS combines public-key cryptography — used to share a key safely — with common-key cryptography — used to exchange data quickly — so communication is both secure and fast. Beyond communication, services stay safe by combining several technologies: encryption hides content, digital certificates prove a site is genuine, digital signatures detect tampering, and multi-factor authentication blocks unauthorized logins. Security online therefore comes from layering these technologies so that many threats are addressed at the same time.

KEY TERMS
digital certificate — proves a site is genuine.
multi-factor authentication — blocks unauthorized logins.

Exercise

1 Cover the Point! section with a red plastic sheet and quiz yourself in your notebook in numerical order.

2 Read the following passage and answer each question.

HTTPS communication, used to access websites safely, combines multiple cryptographic technologies. First, the web server sends a (a) and a public key to the browser. The browser verifies whether the server is authentic through (b). Next, the browser creates a (c) for communication and encrypts it with the server's public key before sending. After this, all data communication is encrypted using this (c).

1. Fill in the blanks (a)–(c).
2. Briefly explain the reason for using common-key cryptography rather than public-key cryptography for data communication.

⭐ REFLECT & CHALLENGE

Reflect: Which of these protections do you rely on most when you go online?
Challenge: Suggest one extra security measure an online shop could add, and one threat it would still not remove.

KEY TERMS
encryption — keeps content private.
digital signature — detects tampering; gives non-repudiation.

3 Answer the following questions.

(1) For each threat (a–d), indicate which technology is primarily used to address it: **A** Encryption, **B** Digital signature, **C** Digital certificate, **D** Multi-factor authentication.

a A password is leaked and unauthorized login occurs.

b Data is altered during communication.

c A user is led to a fake website.

d Communication content is intercepted by a third party.

(2) From the following options (A–D), choose the one that is NOT an appropriate example of multi-factor authentication.

A Password + smartphone notification

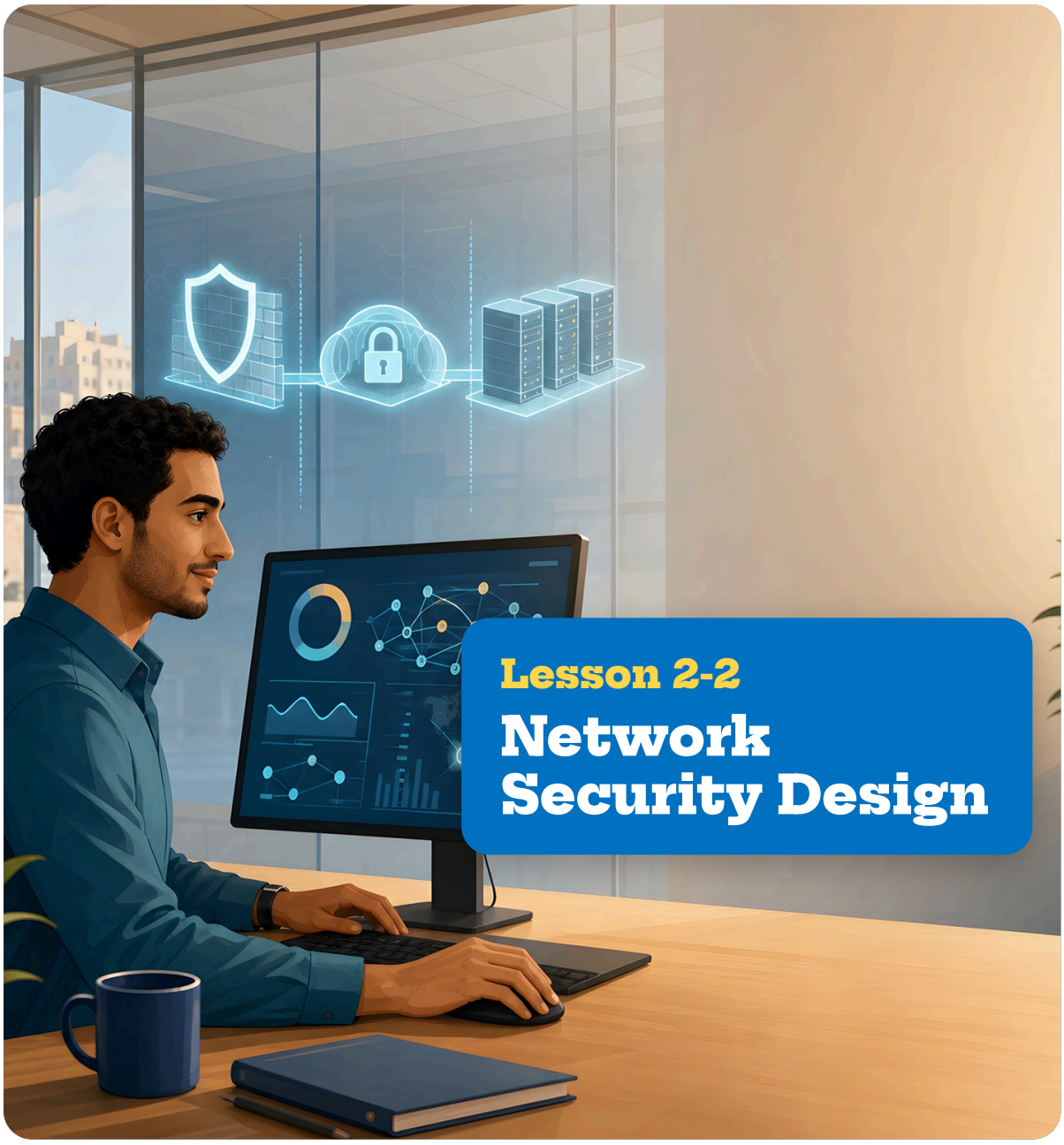
B Password + secret question

C Fingerprint authentication + smart card

D Password + SMS authentication

⭐ Key takeaway

Remember:
HTTPS uses public-key cryptography to share a key safely and common-key cryptography to move data quickly. Services stay safe by layering encryption, certificates, signatures, and multi-factor authentication.



Learning Objectives

- Explain the roles of firewalls, VPNs, and DMZs in protecting a network.
- Describe defense in depth and zero trust, and explain why layered, verified access is stronger than a single barrier.

An organization's network holds confidential data — customer records, financial files, and private messages. Attackers constantly look for a way in. A single lock on the front door is not enough: if it is picked, everything inside is exposed. For this reason, modern network security uses several layers, so that even when one defense is breached, the next one still protects the system.

? Guiding question: How can an organization design its network so that, even if one defense is breached, the system stays protected?

Point!

1. The Role of Firewalls

(1) **(Firewall)**…a system installed at the entry/exit point of a network that allows or denies communication based on rules set in advance.
e.g., Allow access to the web server, but deny direct external access to the database server.

2. VPN (Virtual Private Network)

(1) **(VPN)**…a technology that creates an encrypted virtual private line (tunnel) over the Internet, allowing safe connection to a network from a remote location.

(2) Main uses of VPN

① Remote work…connecting safely to an organization's network from home or while away.

② Connecting branches…connecting offices in different locations safely.

(3) Because communication content is encrypted when using a VPN, the risk of eavesdropping is reduced even when using public Wi-Fi.

3. DMZ (Demilitarized Zone)

(1) **(DMZ)**…an area where servers exposed to the external network (web servers, mail servers, etc.) are placed separately from the internal network.

(2) By providing a DMZ, even if a public-facing server is attacked, damage to the internal network can be prevented.

Key Fact:
Strong network security comes from layering measures — firewall, VPN, DMZ, endpoint protection — and from verifying every access (zero trust), not from a single barrier.

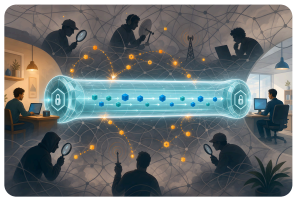
Key Concepts:

- firewall
- VPN
- DMZ
- defense in depth
- zero trust
- perimeter

KEY TERMS
firewall — allows or denies communication at a network's entry/exit point based on preset rules.

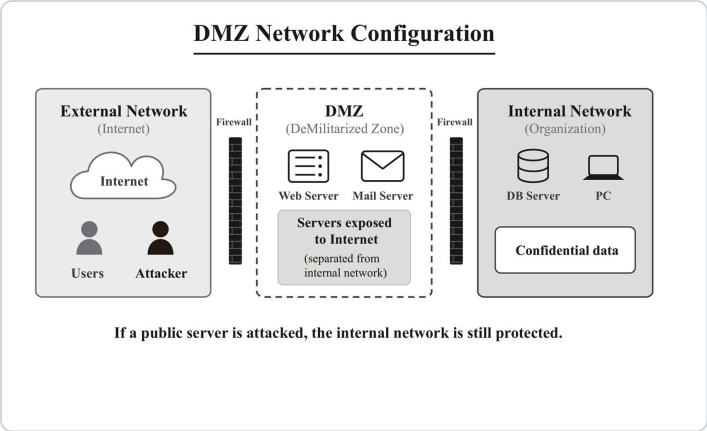


A firewall allows or blocks traffic by rules.



A VPN tunnels data safely through a hostile network.

KEY TERMS
DMZ — a zone for public-facing servers, separated from the internal network.



DMZ Network Configuration

4. Defense in Depth

(1) **(Defense in depth)**…the concept of layering multiple security measures so that, even if one measure is breached, the next can still protect the system.

(2) In network security, multiple measures are combined as follows.

Layer	Examples of measures
Layer 1: Network entry	Block unauthorized communication using a firewall
Layer 2: Communication path	Encrypt communication using a VPN
Layer 3: Server placement	Separate public-facing servers from the internal network using a DMZ
Layer 4: Endpoints	Install antivirus software and keep the OS updated

5. The Concept of Zero Trust

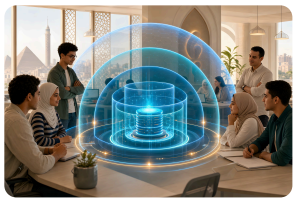
(1) **(Zero trust)**…a security concept that means the system does not trust any communication, including from within the organization's network, and always verifies it.

e.g., Even for access from inside the organization, identity verification and access permission checks are performed every time.

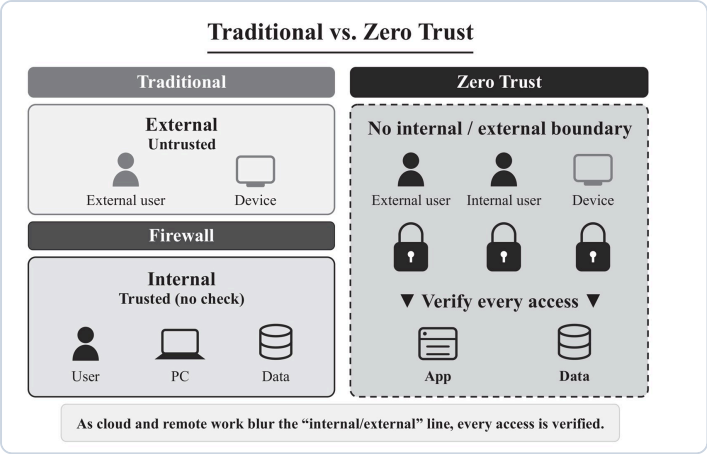
(2) Conventional network security was designed mainly around protecting a perimeter, based on the premise that "inside the organization's network is safe, and outside is dangerous." However, with the spread of cloud services and remote work, the boundary between "inside" and "outside" has become blurred, and designs that protect only the perimeter have become insufficient.

PAUSE & THINK

Why is it safer to place a public web server in a DMZ rather than inside the internal network?



Defense in depth: if one layer falls, the next holds.



Traditional vs. Zero Trust

✎ Worked Example

(1) Mark each statement (A–D) with ○ if true or × if false.

A A firewall allows or denies communication based on rules set in advance.

B Using a VPN can reduce the risk of eavesdropping even on public Wi-Fi.

C A DMZ is a system that exposes all servers to the outside.

D Defense in depth is the concept of layering multiple security measures.

(2) Match each description (a–c) with the most appropriate term from the choices below (A–C).

a A technology that creates an encrypted virtual private line over the Internet for safe connection from a remote location

b An area where servers exposed to the outside are placed separately from the internal network

c A system that allows or denies communication based on rules set in advance

[Choices] **A** Firewall **B** VPN **C** DMZ

✓ Solution

(1)

A A firewall controls communication based on rules. Therefore, ○.

B A VPN encrypts communication, reducing the risk of eavesdropping on public Wi-Fi. Therefore, ○.

C A DMZ is an area where public-facing servers are placed separately from the internal network, not a system that exposes all servers. Therefore, ×.

KEY TERMS

defense in depth — layering measures.

zero trust — verify every access.

D Correct definition of defense in depth. Therefore, ○.

(2)

a: An encrypted virtual private line is a VPN. **B**

b: An area where public-facing servers are isolated is a DMZ. **C**

c: A system that allows or denies communication is a firewall. **A**

Try

1 Answer the following questions.

1. What is the term for the system installed at the entry/exit point of a network that allows or denies communication based on rules?
2. What is the three-letter abbreviation for the technology that creates an encrypted virtual private line over the Internet for safe communication?
3. What is the three-letter abbreviation for the area where servers exposed to the outside are placed separately from the internal network?
4. What is the term for the concept of layering multiple security measures?

2 Answer the following questions.

(1) From the following options (A–D), choose the one that is NOT an appropriate use of a VPN.

A Connecting safely from home to an organization's network

B Connecting offices in different locations safely

C Automatically deleting files infected with viruses

D Encrypting communication content on public Wi-Fi

(2) For each of the security measures (a–d), indicate which layer of defense in depth (A–D) it belongs to.

a Blocking unauthorized communication with a firewall

b Encrypting communication with a VPN

c Installing antivirus software

d Separating public-facing servers from the internal network using a DMZ

[Layers] **A** Network entry **B** Communication path **C** Server placement **D** Endpoints

Think as an Engineer — Investigate & Decide

A company in your city is setting up its office network. It has a public website, staff who work from home, and confidential customer data. You advise on the security design.

EXAM-STYLE QUESTION

Explain why layering several security measures (defense in depth) protects an organization better than relying on a firewall alone. **[6] Refer to:** what happens if one measure is breached.

☐ A firewall only

☐ A layered design (firewall + VPN + DMZ + endpoints) that also verifies every access (zero trust)

1 · Collect data. List the company's three assets (public website, remote staff, customer database) and the main threat to each.

2 · Rank the layers. For this company, rank the four defense-in-depth layers (network entry, communication path, server placement, endpoints) from most to least critical, and justify your top choice.

3 · Decide. Recommend a design and give two reasons why layering is safer than a single firewall. **In pairs,** compare your designs and agree together on the strongest reason before you write it down.

Give evidence for your answer.

Stuck? Start with the most exposed asset — the public website — and place it in a DMZ so that an attack there cannot reach the internal database.

🌍 In a New Context

A hospital moves its patient records to a cloud service and lets doctors access them from home. Using zero trust and defense in depth, suggest two measures it should apply and say where each one helps, then identify one risk that could still remain.

❓ Lesson Question — Answered

The lesson asked how to design a network so that one breach does not expose everything. The answer is layering. A firewall controls what enters and leaves the network; a VPN encrypts communication from remote locations; a DMZ separates public-facing servers so that an attack on them cannot reach internal data; and endpoint measures protect each device. Because cloud services and remote work have blurred the line between "inside" and "outside," zero trust adds a further principle: no access is trusted automatically, and every request is verified. Together, defense in depth and zero trust keep the network protected even when a single measure fails.

KEY TERMS

perimeter — the old "inside is safe" boundary that cloud and remote work have blurred.

Exercise

1 Cover the Point! section with a red plastic sheet and quiz yourself in your notebook in numerical order.

2 Read the following passage and answer each question.

To protect an organization's network, it is important to combine multiple security measures. First, a (a) is installed at the entry/exit point of the network to block unauthorized communication based on rules. Web servers and other servers exposed to the outside are placed in a (b), separated from the internal network. To connect safely from outside, such as with remote work, communication is encrypted using a (c). The concept of layering multiple measures in this way is called (d).

1. Fill in the blanks (a)–(d).

3 Answer the following questions.

(1) From the following options (A–D), choose the most appropriate reason for providing a DMZ.

A To improve communication speed.

B To expose all servers to the outside.

C To prevent damage to the internal network even if a public-facing server is attacked.

D To automatically detect and remove viruses.

(2) From the following options (A–D), choose the one that most appropriately describes the concept of zero trust.

A Access from within the organization's network is safe, so verification is unnecessary.

B A firewall alone is sufficient to protect the network.

C No communication is trusted and is always verified.

D Only access from outside needs to be monitored.

⭐ REFLECT & CHALLENGE

Reflect: Which layer of defense do you think is easiest for an attacker to get past, and why?
Challenge: Suggest one measure a small company could add beyond a firewall, and one threat it would still not remove.

⭐ Key takeaway

Remember:
Layer your defenses — firewall, VPN, DMZ, endpoints — and verify every access (zero trust). One breach is then far less likely to expose the whole network.



Lesson 2-3

Incident Response and Risk Management

Learning Objectives

- Explain what a security incident is and describe the stages of incident response in the correct order.
- Apply the idea of risk assessment by prioritizing risks according to their impact and likelihood.

Even a well-protected system can be attacked. When a security incident happens — data leaked, files tampered with, or a service knocked offline — a rushed and unplanned reaction only makes the damage worse. Organizations follow a clear, ordered response so that damage is contained, the cause is removed, and the same problem does not return. They also decide in advance which risks to guard against first, because no team can fix everything at once.

? Guiding question: When a security incident happens, how should an organization respond in order — and how does it decide which risks to address first?

Key Fact:
Incident response follows six ordered stages, and risk assessment prioritizes risks by impact × likelihood — so an organization acts in the right order and on the right risks first.

Key Concepts:

- security incident
- the six stages
- containment / eradication
- risk = impact × likelihood

KEY TERMS
security incident — a situation in which actual damage occurs due to an information security problem.

Point!

1. What is a Security Incident

(1) **(Security incident)**…a situation in which actual damage occurs due to an information security problem.

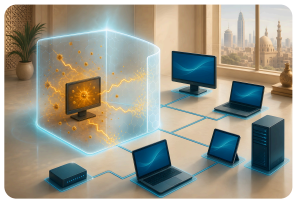
(2) Typical examples of security incidents

Type	Description
Information leak	Personal information or confidential information is leaked to the outside
Data tampering	Data within a system is altered without authorization
Service outage	A service becomes unavailable due to attacks on the server, etc.

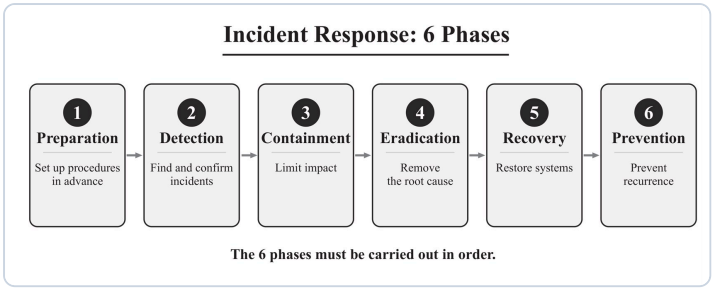
2. The Flow of Incident Response

(1) When a security incident occurs, response proceeds through the following six stages.

Stage	Description
① **Preparation**	Establish response procedures and structures in advance, in preparation for incidents
② **Detection**	Discover and confirm that an incident has occurred
③ **Containment**	Limit the scope of impact so that damage does not spread further
④ **Eradication**	Remove the cause of the incident (e.g., remove malware)
⑤ **Recovery**	Return systems and services to their normal state
⑥ **Prevention of recurrence**	Analyze the cause and take measures so that the same incident does not occur again



Contain first: isolate the infected machine.



Incident Response: 6 Phases

(2) It is important to proceed through the six stages of incident response in order. For example, if recovery is performed without identifying the cause, the same incident may occur again.

3. The Concept of Risk Assessment

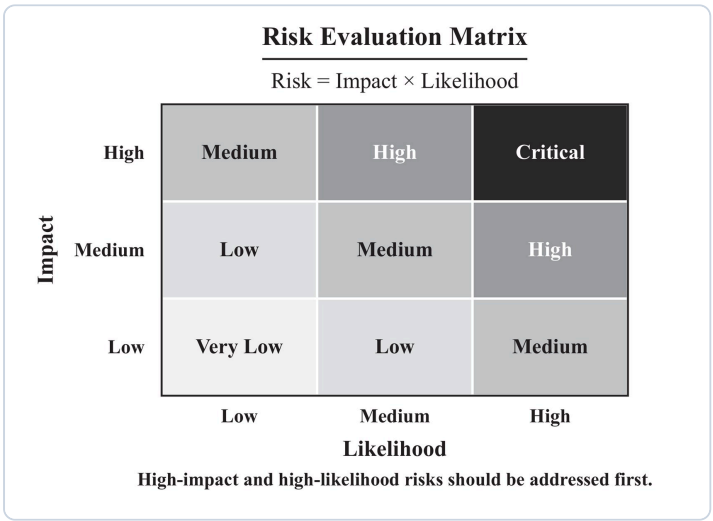
(1) **(Risk)**…the possibility of an information security problem occurring in the future, and its impact.

(2) The size of a risk is determined by the following two factors.

$$\text{Risk size} = \text{Impact} \times \text{Likelihood}$$

① **(Impact)**…how much damage occurs if the risk actually materializes.

② **(Likelihood)**…how high the probability is that the risk will actually materialize.



Risk Evaluation Matrix

(3) Risks with both high impact and high likelihood should be addressed first. Since it is difficult to address all risks at the same time, it is important to set priorities and take measures systematically.

✎ Worked Example

(1) Mark each statement (A–D) with ○ if true or × if false.

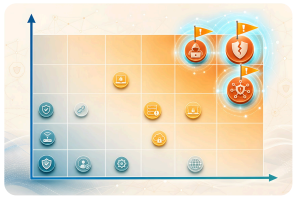
A A security incident is a situation in which actual damage occurs due to an information security problem.



Recover: restore a clean system from backup.

PAUSE & THINK

Why must containment come before eradication in the six-stage response?



Rank risks by impact and likelihood; fix the worst first.

KEY TERMS

impact — how much damage if a risk occurs.

likelihood — how probable the risk is.

B In incident response, it is important to first prevent the spread of damage before removing the cause.

C The size of a risk can be determined by impact alone.

D The final stage of incident response is prevention of recurrence.

(2) For each of a–d, indicate which stage of the six stages of incident response (A–D) it belongs to.

a Establishing response procedures in advance, in preparation for incidents

b Disconnecting a malware-infected computer from the network

c Removing the malware infection

d Analyzing the cause and taking measures so that the same incident does not occur again

[Choices] **A** Preparation **B** Containment **C** Eradication **D** Prevention of recurrence

✓ Solution

(1)

A Correct definition of a security incident. Therefore, ○.

B Containment (preventing the spread of damage) is performed before eradication (removing the cause). Therefore, ○.

C The size of a risk is determined by both impact and likelihood. Therefore, ×.

D The final stage of the six stages is prevention of recurrence. Therefore, ○.

(2)

a: Preparing in advance is preparation. **A**

b: Disconnecting from the network to prevent the spread of damage is containment. **B**

c: Removing malware is eradication. **C**

d: Cause analysis and countermeasures are prevention of recurrence. **D**

EXAM-STYLE QUESTION

Explain why the six stages of incident response must be carried out in order, using recovery and eradication as an example. **[6] Refer to:** what happens if the cause is not removed.

Try

1 Answer the following questions.

1. What is the term for a situation in which actual damage occurs due to an information security problem?
2. Name the six stages of incident response in order.
3. What are the two factors used to determine the size of a risk?

2 Answer the following questions.

(1) From the following options (A–D), choose the one that is NOT an appropriate example of a security incident.

A Data was encrypted by a ransomware infection.

B Customer information was leaked to the outside through unauthorized access.

C A software update was performed to add new features.

D A web service became unavailable due to an attack on the server.

(2) From the following options (A–D), choose the one that most appropriately describes the concept of risk assessment.

A It is enough to address only risks with large impact.

B It is enough to address only risks with high likelihood.

C Risks with both high impact and high likelihood should be addressed first.

D All risks must be addressed simultaneously.

⚙ Think as an Engineer — Investigate & Decide

A school's student-records system is hit by ransomware: files are encrypted and staff cannot log in. You lead the response.

☐ **Restore from backup immediately**

☐ **Follow the six-stage response in order**

1 · Respond from here. This incident has just been **detected** — files are encrypted and staff are locked out. Starting from where the school is **now**, list the stages still to carry out, and say what each one means for this specific incident.

2 · Assess the risks. For two risks the school faces — (i) another ransomware attack, (ii) a brief power cut — estimate impact and likelihood, and say which to address first.

3 · Decide. Recommend the first three actions the school should take, and give one reason why order matters. **In pairs,** compare your orders and agree together on the single most important first step.

Give evidence for your answer.

Stuck? If you recover before you eradicate the cause, the malware is still there — and the same incident can happen again.

🌍 In a New Context

An online shop has just **detected** that customer data has been leaked. Using the six-stage response and risk assessment, name the next two stages it should carry out and why, and identify one risk it should prioritize afterward.

❓ Lesson Question — Answered

The lesson asked how to respond to an incident in order, and how to prioritize risks. A security incident is any situation where real damage occurs. The response follows six stages in a fixed order — preparation, detection, containment, eradication, recovery, and prevention of recurrence — because acting out of order (for example, recovering before removing the cause) lets the same incident return. To decide what to guard against first, an organization assesses each risk by its size = impact × likelihood, and addresses high-impact, high-likelihood risks first, since no team can fix everything at once. Responding in order and prioritizing by risk together keep damage small and prevent repeats.

KEY TERMS

containment — limit the spread of damage.

eradication — remove the cause.

Exercise

1 Cover the Point! section with a red plastic sheet and quiz yourself in your notebook in numerical order.

2 Read the following passage and answer each question.

A situation in which actual damage occurs due to an information security problem is called (a). When (a) occurs, (b), which prevents the spread of damage, is performed first, followed by (c), which removes the cause of the incident. After that, (d), which returns the system to its normal state, is performed, and finally (e), in which the cause is analyzed to prevent recurrence, is performed.

⭐ REFLECT & CHALLENGE

Reflect: Which stage of incident response do you think is hardest to do well under pressure, and why? **Challenge:** Suggest one thing an organization could prepare in advance (stage 1) that would make the other phases faster.

1. Fill in the blanks (a)–(e).

3 Answer the following questions.

(1) Reorder the risks (a–d) from highest priority to lowest priority based on the concept of risk assessment (impact × likelihood).

a Impact: large (3), Likelihood: high (3)

b Impact: small (1), Likelihood: high (3)

c Impact: large (3), Likelihood: medium (2)

d Impact: small (1), Likelihood: low (1)

(2) From the following options (A–D), choose the one that most appropriately describes the order of incident response.

A Detection → Eradication → Containment → Recovery

B Preparation → Detection → Containment → Eradication → Recovery → Prevention of recurrence

C Detection → Recovery → Containment → Prevention of recurrence

D Containment → Detection → Eradication → Preparation

⭐ Key takeaway

Remember:
Follow the six stages in order (prepare → detect → contain → eradicate → recover → prevent), and prioritize risks by impact × likelihood.